

Informe HyVAW.

HyVAW propone un flujo híbrido de análisis de vulnerabilidades que, bien entendido, se presta de maravilla a generar indicadores cuantitativos y cualitativos para medir la exposición y la resiliencia de sistemas distribuidos a gran escala; la gracia, para nuestro caso, es “estirar” esos indicadores hasta el nivel de un territorio nacional como España y compararlos con lo que están haciendo otros países bajo el paraguas de NIS2 y marcos afines.¹²³

1. Qué es HyVAW y por qué importa para indicadores

HyVAW (“Hybrid Vulnerability Analysis Workflow”) se presenta en 2025 como una metodología de threat modeling y análisis de vulnerabilidades para sistemas complejos basados en componentes distribuidos. La idea central es coordinar, en un único flujo, técnicas estáticas, dinámicas y de verificación sobre arquitecturas donde confluyen servicios, dispositivos de borde, redes industriales y componentes en la nube.⁴⁵⁶⁷⁸

El trabajo enfatiza que el análisis aislado (solo estático, solo pentest, solo escáner) deja “puntos ciegos” en sistemas distribuidos y que un flujo híbrido puede reducir falsos positivos y falsos negativos, al correlacionar hallazgos en diferentes fases y capas. Esa correlación es precisamente el material del que se alimentan indicadores de calidad del análisis y de riesgo residual, que es lo que nos interesa para una visión país.⁹¹⁰

1 <https://www.nis-2-directive.com/Transposition/Spain.html>

2 <https://www.ie.edu/cgc/research/cyber-readiness-in-spain/>

3 <https://www.sciencedirect.com/science/article/pii/S2199853125001891>

4 <https://dl.acm.org/doi/10.1145/3381038>

5 <https://orcid.org/0000-0002-7213-1603>

6 <https://www.inf.ufsc.br/~carlos.westphall/other.htm>

7 <https://ouci.dntb.gov.ua/works/420VY3ze/>

8 <https://www.nis-2-directive.com/Transposition/Spain.html>

9 <https://www.techscience.com/CMES/v126n1/40863/html>

10 <https://www.nis-2-directive.com/Transposition/Spain.html>

2. Núcleo del HyVAW: fases e indicadores internos

En la literatura de análisis híbrido de vulnerabilidades (incluyendo HyVAW y métodos afines como Hy2 y metodologías híbridas para aplicaciones web) se repiten algunos elementos estructurales que terminan cristalizando en indicadores medibles.¹¹¹²¹³

HyVAW y las metodologías híbridas comparables suelen organizarse en fases que, simplificando, incluyen:

1. Modelado del sistema y del atacante: identificación de activos, componentes, flujos de datos, límites de confianza y categorías de atacante, generando modelos de amenaza y árboles de ataque. Aquí emergen indicadores como “cobertura de activos modelados” y “densidad de amenazas por activo”.¹¹⁵¹
2. Descubrimiento de vulnerabilidades: uso combinado de análisis estático, dinámico, emulación, pruebas manuales y herramientas específicas por tecnología para descubrir debilidades en cada componente y en las interacciones entre ellos. Aquí aparecen indicadores clásicos de gestión de vulnerabilidades, pero refinados por contexto híbrido: número de vulnerabilidades por tipo de componente, por flujo de datos, por vector de ataque.¹¹⁹⁸
3. Correlación y reducción de ruido: comparación entre hallazgos estáticos y dinámicos, clasificación TP/FP (verdaderos/falsos positivos) y priorización según explotabilidad y criticidad del activo. Esto permite indicadores internos de calidad del flujo, como “tasa de falsos positivos”, “proporción de vulnerabilidades confirmadas dinámicamente” o “vulnerabilidades multi-fase (presentes en varias capas)”.¹²⁹⁸
4. Evaluación de impacto y riesgo: mapeo de vulnerabilidades a escenarios de impacto para el negocio o el servicio esencial, muchas veces apoyándose en taxonomías como CVSS pero refinadas en función del modelo de amenazas específico. Aquí emergen indicadores de riesgo agregado y de exposición por dominio funcional.⁵¹
5. Remediación y revalidación: cierre del ciclo con la aplicación de medidas correctivas, su verificación y la actualización de los modelos de amenaza. Se nutren indicadores de tiempo, eficacia y “memoria organizativa”.¹²⁸¹¹

En la práctica, la literatura técnica señala explícitamente métricas de referencia para calibrar la parte híbrida: proporción de vulnerabilidades detectadas por análisis dinámico que no aparecieron en

¹¹ <https://ouci.dntb.gov.ua/works/420VY3ze/>

¹² <https://www.nis-2-directive.com/Transposition/Spain.html>

¹³ <https://www.techscience.com/CMES/v126n1/40863/html>

estático, reducción de falsos positivos tras la fase dinámica, y capacidad del enfoque híbrido para descubrir vulnerabilidades críticas adicionales.¹⁴¹⁵¹⁶

3. Tipos de indicadores HyVAW: del laboratorio al tablero país

Si uno mira HyVAW y trabajos afines con mala leche estadística, lo que ve es un productor industrial de indicadores en varias capas. A efectos de un informe nacional para España, interesa distinguir tres niveles: micro (componente), meso (sistema / organización crítica) y macro (sector / país).¹⁷¹⁸

En el nivel micro, HyVAW trabaja con indicadores muy próximos a la ingeniería de vulnerabilidades:

- Detecciones y calidad del análisis: número de vulnerabilidades totales, distribuidas por severidad, tipo (configuración, lógica, criptografía, etc.) y origen (estático, dinámico, manual).⁹¹⁰⁸
- Rendimiento del flujo híbrido: tasa de verdaderos positivos frente a falsos positivos, porcentaje de hallazgos confirmados mediante análisis dinámico, vulnerabilidades nuevas descubiertas solo por el enfoque híbrido.⁸⁹¹²
- Cobertura: porcentaje de componentes y rutas de ejecución cubiertas por el análisis, medido frente al modelo de sistema.⁵¹

En el nivel meso (organización o sistema crítico), las métricas se acercan al lenguaje de NIS2 y de los marcos de gestión de vulnerabilidades:

- Exposición por dominio: densidad de vulnerabilidades por servicio esencial (banca, transporte, energía, salud, administración pública, etc.).¹³²³
- Eficacia de la remediación: tiempo medio de remediación (TTR) por severidad, porcentaje de vulnerabilidades cerradas dentro de los plazos objetivo, frecuencia de reaparición de vulnerabilidades de la misma clase.¹²⁸
- Resiliencia operacional: reducción de incidentes reales asociables a vulnerabilidades previamente identificadas, indicadores de continuidad y tiempo medio entre incidentes derivados de fallos de seguridad.³¹²

En el nivel macro nacional, donde HyVAW se convierte en un generador de estadísticas país, los indicadores se alinean con la forma en que España ya reporta incidentes y sistemas vulnerables a través de INCIBE y CCN. A partir de 2025, INCIBE reporta: más de 122.000 incidentes atendidos (+26%), más de

¹⁴ <http://people.scs.carleton.ca/~soma/pubs/students/emma-sewell-mcs.pdf>

¹⁵ <https://ouci.dntb.gov.ua/works/420VY3ze/>

¹⁶ <https://www.techscience.com/CMES/v126n1/40863/html>

¹⁷ <https://www.nis-2-directive.com/Transposition/Spain.html>

¹⁸ <https://www.techscience.com/CMES/v126n1/40863/html>

237.000 sistemas vulnerables relevantes identificados, decenas de miles de casos de malware y fraude, y cientos de incidentes en operadores esenciales regulados por NIS2.¹⁹²⁰²¹²²²³

HyVAW añade una dimensión de calidad a ese inventario: no solo cuántos sistemas vulnerables hay, sino cuánto de esa vulnerabilidad ha sido analizada de forma híbrida, con qué profundidad, y qué fracción se refleja en incidentes reales. El indicador “sistemas vulnerables relevantes detectados por módulos HyVAW” puede convertirse en una métrica de madurez en gestión proactiva frente al mero conteo de incidentes.²⁴²⁵²⁶

4. España, NIS2 y el juego de indicadores: cómo encaja HyVAW

A nivel regulatorio, España está en pleno proceso de transposición de la Directiva NIS2 mediante una ley de coordinación y gobernanza de la ciberseguridad que reorganiza la arquitectura institucional (CCN, INCIBE y nuevas estructuras como un Centro Nacional de Ciberseguridad coordinador). NIS2 amplía el alcance a más sectores y refuerza las obligaciones de gestión de riesgos, medidas técnicas y organizativas, y notificación de incidentes, bajo un régimen de responsabilidad de la alta dirección bastante menos amable que en el pasado.²⁷²⁸²⁹

ENISA, por su parte, publicó en 2025 una guía técnica de implementación de medidas de gestión de riesgos de ciberseguridad que baja a tierra el reglamento de ejecución de NIS2, organizando las obligaciones en áreas temáticas con ejemplos concretos de evidencias y métricas. En ese catálogo, la gestión de vulnerabilidades y la evaluación de riesgos técnicos aparecen como áreas obligatorias, con

19 <https://www.ie.edu/cgc/research/cyber-readiness-in-spain/>

20 <https://www.sciencedirect.com/science/article/pii/S2199853125001891>

21 <https://www.ie.edu/cgc/research/cyber-readiness-in-spain/>

22 <https://dl.acm.org/doi/10.1145/3381038>

23 <https://orcid.org/0000-0002-7213-1603>

24 <https://www.inf.ufsc.br/~carlos.westphall/other.htm>

25 <https://www.nis-2-directive.com/Transposition/Spain.html>

26 <https://www.techscience.com/CMES/v126n1/40863/html>

27 <https://ouci.dntb.gov.ua/works/420VY3ze/>

28 <https://www.techscience.com/CMES/v126n1/40863/html>

29 <https://www.sciencedirect.com/science/article/pii/S2199853125001891>

expectativas claras de indicadores como cobertura de escaneos, tiempos de remediación, y reducción de incidentes vinculados.³⁰³¹

Aquí es donde HyVAW deja de ser un capricho académico y se convierte en una herramienta políticamente útil: permite definir indicadores de cumplimiento de NIS2 que van más allá del “hemos pasado un escáner”. Una organización española regulada podría, por ejemplo, demostrar:

- Porcentaje de sistemas esenciales analizados mediante flujo híbrido, frente al total de sistemas críticos declarados para NIS2.2112
- Tasa de reducción de falsos positivos en vulnerabilidades críticas tras introducir HyVAW, como evidencia de mejora de la gestión de riesgos.⁹⁸¹²
- Correlación entre vulnerabilidades de alto impacto identificadas y ausencia de incidentes graves en esos vectores en el período siguiente.³¹³¹²

A nivel país, la agregación de estos indicadores —siempre que las organizaciones compartan datos de forma anonimizada— permitiría construir un “baseline nacional de madurez y resiliencia NIS2” de tipo cuantitativo como el que proyectos académicos en España ya están empezando a elaborar mediante modelos de diagnóstico estructural.³²

5. Comparativa internacional: tendencias globales 2025–2026

Desde 2025, la investigación en threat modeling y análisis híbrido ha seguido varias líneas convergentes con el espíritu de HyVAW. Por un lado, trabajos de revisión sobre protocolos de IIoT y metodologías de evaluación de riesgo han subrayado la necesidad de modelos que combinen análisis estructural con evaluación dinámica del comportamiento de sistemas distribuidos, especialmente en entornos industriales y críticos.³³³⁴

Por otro, se observa un auge de herramientas y marcos que automatizan parte del threat modeling, incluso aplicados a arquitecturas de IA generativa, usando metodologías híbridas donde se combinan análisis estático de diseño con pruebas dinámicas y simulación de ataques; HyVAW es citado como una referencia reciente en metodologías de threat modeling para sistemas complejos.³⁵³⁶

³⁰ <http://people.scs.carleton.ca/~soma/pubs/students/emma-sewell-mcs.pdf>

³¹ <https://ouci.dntb.gov.ua/works/420VY3ze/>

³² <https://reunir.unir.net/handle/123456789/11242>

³³ <https://eiposgrados.com/eng/cybersecurity-blog/cybersecurity-incidents-in-spain-2025-incibe-report/>

³⁴ <https://orcid.org/0000-0002-7213-1603>

³⁵ https://www.meegle.com/en_us/topics/vulnerability-management/vulnerability-management-in-hybrid-it-environments

³⁶ <https://www.nis-2-directive.com/Transposition/Spain.html>

En cuanto a indicadores, la tendencia global en gestión de vulnerabilidades en entornos híbridos (nube, on-prem, OT) privilegia un conjunto relativamente estable de KPIs, entre los que destacan: tiempo medio de remediación, número de vulnerabilidades resueltas en un periodo, grado de cobertura de activos, tasa de incidentes atribuibles a vulnerabilidades conocidas, y grado de cumplimiento regulatorio. El matiz HyVAW está en su énfasis en métricas de calidad del propio proceso de análisis (falsos positivos, confirmación dinámica, cobertura frente al modelo de sistema), que se alinea con las exigencias más finas de ENISA en términos de “efectividad” de las medidas de gestión de riesgos más que su mera existencia.³⁷³⁸³⁹

Frente a otros países europeos, España parte de una posición razonablemente robusta en volumen de capacidad institucional (INCIBE, CCN, futuras estructuras bajo la nueva ley), pero con cifras crecientes de incidentes y sistemas vulnerables que muestran que la exposición va por delante de la mitigación. Integrar indicadores de corte HyVAW en los informes nacionales permitiría distinguir entre “más incidentes porque el panorama es peor” y “más incidentes porque se está midiendo mejor y mitigando antes”, matiz que no es menor cuando hay que explicarle las cosas a la opinión pública y a Bruselas.⁴⁰⁴¹⁴²⁴³

6. Propuesta concreta de indicadores HyVAW para España (con vocación comparativa)

Si uno quisiera diseñar, a partir de la literatura, un conjunto de indicadores HyVAW adaptado al nivel nacional español y comparable internacionalmente, podría articularlo en cuatro bloques: cobertura, calidad del análisis, gestión de vulnerabilidades y resultados operativos. Cada bloque se alimenta de datos que ya se recogen (INCIBE, CCN, informes sectoriales) más los que aportaría la adopción de flujos HyVAW en sectores esenciales.⁴⁴⁴⁵⁴⁶⁴⁷⁴⁸

³⁷ <https://ouci.dntb.gov.ua/works/420VY3ze/>

³⁸ <https://www.techscience.com/CMES/v126n1/40863/html>

³⁹ <http://espanadigital.gob.es/va/actualidad/incibe-gestiono-122223-incidentes-de-ciberseguridad-en-2025-un-26-mas-que-el-ano>

⁴⁰ <http://people.scs.carleton.ca/~soma/pubs/students/emma-sewell-mcs.pdf>

⁴¹ <https://eiposgrados.com/eng/cybersecurity-blog/cybersecurity-incidents-in-spain-2025-incibe-report/>

⁴² <https://cyberlur.es/blog/cyberlur-5/incibe-presenta-el-balance-de-ciberseguridad-2025-mas-incidentes-mas-fraude-y-mayor-presion-regulatoria-157>

⁴³ <https://www.sciencedirect.com/science/article/pii/S2199853125001891>

⁴⁴ <https://www.ie.edu/cgc/research/cyber-readiness-in-spain/>

⁴⁵ <https://reunir.unir.net/handle/123456789/11242>

⁴⁶ <https://www.twobirds.com/en/insights/2025/eu-cybersecurity--enisa-publishes-final-nis2-guidance>

Un esquema posible podría ser:

6. Cobertura híbrida de análisis

Porcentaje de sistemas esenciales en sectores NIS2 analizados mediante flujos híbridos (HyVAW u otros equivalentes) al menos una vez al año.

Cobertura de componentes y flujos críticos en los modelos de amenaza utilizados, respecto al inventario de activos críticos declarado a la autoridad competente.

7. Calidad del proceso de análisis

Tasa de verdaderos positivos frente a falsos positivos en vulnerabilidades críticas, medida antes y después de la adopción de análisis híbrido.

Proporción de vulnerabilidades críticas confirmadas mediante análisis dinámico o pruebas manuales sobre el total de vulnerabilidades críticas detectadas.

Número medio de fases del flujo (estático, dinámico, emulación, revisión manual) por vulnerabilidad crítica confirmada, como proxy de profundidad analítica.

8. Gestión de vulnerabilidades y tiempos

Tiempo medio de remediación de vulnerabilidades críticas y altas, con objetivos diferenciados por sector (banca, energía, transporte, sanidad, administración pública)..¹³²¹²

Porcentaje de vulnerabilidades cerradas dentro del plazo objetivo acordado con la autoridad competente o definido internamente.

Tasa de reincidencia de vulnerabilidades por clase (por ejemplo, inyecciones, problemas de autenticación, mala configuración), como indicador de aprendizaje organizativo.

9. Resultados operativos y riesgo residual

Densidad de incidentes de ciberseguridad por 1.000 sistemas vulnerables identificados, discriminando aquellos en los que la vulnerabilidad explotada estaba previamente detectada por el flujo híbrido..¹⁵¹⁴¹³

Número de incidentes graves (interrupción significativa de servicios esenciales) por año que podrían haberse evitado mediante remediación de vulnerabilidades ya identificadas, como indicador de “riesgo por inacción”.

Evolución anual de sistemas vulnerables relevantes detectados (como ya publica INCIBE) cruzada con el porcentaje de esos sistemas cubiertos por flujos híbridos, para medir si la mejora en capacidad de análisis va acompañada con la reducción de riesgo país.¹³¹²

⁴⁷ <https://www.techscience.com/CMES/v126n1/40863/html>

⁴⁸ <https://www.sciencedirect.com/science/article/pii/S2199853125001891>

- Porcentaje de sistemas esenciales en sectores NIS2 analizados mediante flujos híbridos (HyVAW u otros equivalentes) al menos una vez al año.
- Cobertura de componentes y flujos críticos en los modelos de amenaza utilizados, respecto al inventario de activos críticos declarado a la autoridad competente.
- Tasa de verdaderos positivos frente a falsos positivos en vulnerabilidades críticas, medida antes y después de la adopción de análisis híbrido.
- Proporción de vulnerabilidades críticas confirmadas mediante análisis dinámico o pruebas manuales sobre el total de vulnerabilidades críticas detectadas.
- Número medio de fases del flujo (estático, dinámico, emulación, revisión manual) por vulnerabilidad crítica confirmada, como proxy de profundidad analítica.
- Tiempo medio de remediación de vulnerabilidades críticas y altas, con objetivos diferenciados por sector (banca, energía, transporte, sanidad, administración pública)..13212
- Porcentaje de vulnerabilidades cerradas dentro del plazo objetivo acordado con la autoridad competente o definido internamente.
- Tasa de reincidencia de vulnerabilidades por clase (por ejemplo, inyecciones, problemas de autenticación, mala configuración), como indicador de aprendizaje organizativo.
- Densidad de incidentes de ciberseguridad por 1.000 sistemas vulnerables identificados, discriminando aquellos en los que la vulnerabilidad explotada estaba previamente detectada por el flujo híbrido..151413
- Número de incidentes graves (interrupción significativa de servicios esenciales) por año que podrían haberse evitado mediante remediación de vulnerabilidades ya identificadas, como indicador de “riesgo por inacción”.
- Evolución anual de sistemas vulnerables relevantes detectados (como ya publica INCIBE) cruzada con el porcentaje de esos sistemas cubiertos por flujos híbridos, para medir si la mejora en capacidad de análisis va acompañada con la reducción de riesgo país.1312

Estos indicadores son comparables a nivel europeo en la medida en que los demás Estados miembros, también sujetos a NIS2 y a la guía de ENISA, convergerán en métricas de cobertura y eficacia de la gestión de vulnerabilidades; la diferencia está en el grado de “hibridación” y profundidad técnica, donde HyVAW marca un estándar alto que podría servir como referencia para la propia ENISA en futuras revisiones.⁴⁹⁵⁰

Como paso siguiente, sería razonable construir un modelo de madurez nacional en el que las organizaciones españolas sometidas a NIS2 se sitúen en niveles según su integración de flujos híbridos de análisis y la calidad de sus indicadores; iniciativas de investigación en España ya están desarrollando marcos de diagnóstico de ciber-resiliencia que podrían incorporar este tipo de métricas sin demasiada violencia epistemológica.⁵¹

49 <https://help.drata.com/en/articles/12150854-nis2-update-what-enisa-s-new-guidance-means-for-you>

50 <https://discovery.researcher.life/topic/threat-model/8753978?page=4>

51 <https://www.semanticscholar.org/paper/7bae4ddeb3df0d613a05dac4e60abf8c7539c655>

20212223242526